Assessment Report

Site: https://propel.earth/
Assessed: Mon, 26 Oct 2026 20:13:54 GMT
Assessment ID: a6e72d0e-bf42-47b1-8a6b-6729871c9c7d
Pages scanned: 3 (https://propel.earth/, https://propel.earth/marketplace/asks/l3cNpC8T2m0Ht8FNafyC, https://propel.earth/marketplace/asks/Rcaay3T9Fo58x7aJXfIX)

Scores

Security score: 92/100
Accessibility score: 100/100
Findings: 3 total — 0 critical, 0 high, 1 medium, 0 low, 1 informational; 1 need manual verification.
Scores are a triage aid computed from automated findings, not a certification. See the closing section for what this assessment does not claim.

Authorization & evidence

Authorization confirmed by the site owner or their authorized agent at 2026-10-26T20:13:54.929Z.
Statement: I confirm that I own this website or hold written authorization from its owner to assess it, and I understand this assessment uses passive observation and automated checks only — no exploitation, no load testing, no access attempts.
Evidence integrity hash (SHA-256):
a79fb532f55d6606f324ced3151a15a9310f4f05c34a8ac51098241681c77a9f
Engine: accessguard-engine/1.0 (passive headers + axe-core 4.14)

Findings

[MEDIUM] Content-Security-Policy allows unsafe inline/eval scripts

Security · Security headers & transport (OWASP / Mozilla Observatory practice) · rule: csp-weak

A CSP is present but permits 'unsafe-inline' or 'unsafe-eval' for scripts without nonces or hashes, which removes most of its protection against injected scripts.

Business impact

The header creates a false sense of coverage: injected inline scripts still run.

How to fix

Move inline scripts to files or protect them with per-response nonces/hashes, then remove 'unsafe-inline' and 'unsafe-eval' from script-src.

Evidence

• https://propel.earth/ — content-security-policy: default-src 'self';script-src 'self' 'unsafe-inline' https://storage.googleapis.com https://apis.google.com https://cdn.gpteng.co https://www.googletagmanager.com https://*.firebaseio.com https://cdn.cortality.com;style-src 'self' 'unsafe-inline' https://fonts.googleapis.com https://api.fontshare.co

[LOW · NEEDS REVIEW] Elements must meet minimum color contrast ratio thresholds — needs manual verification

Accessibility · WCAG 1.4.3 (Level AA) · rule: color-contrast

Automated testing could not determine whether this passes or fails, so it is recorded for human review rather than scored as a failure. Ensure the contrast between foreground and background colors meets WCAG 2 AA minimum contrast ratio thresholds

Business impact

Text that fails contrast minimums is unreadable for people with low vision and difficult for everyone in bright light or on cheap screens.

How to fix

Darken text or lighten its background until body text reaches 4.5:1 and large text 3:1 against its background. (Reference: https://dequeuniversity.com/rules/axe/4.14/color-contrast?application=axeAPI)

Evidence

• https://propel.earth/ — Fix all of the following: Axe encountered an error; test the page for this type of problem manually

<h1>Propel Earth</h1>
• https://propel.earth/marketplace/asks/I3cNpC8T2m0Ht8FNafyC — Fix all of the following: Axe encountered an error; test the page for this type of problem manually
<h1>Meeting US based companies looking to expand into Australia.</h1>
• https://propel.earth/marketplace/asks/Rcaay3T9Fo58x7aJXfIX — Fix all of the following: Axe encountered an error; test the page for this type of problem manually
<h1>Looking for CPO / Technical Co-Founder – Local-First AI & Assistive Tech</h1>

[INFO] Server technology disclosed in response headers

Security · Security headers & transport (OWASP / Mozilla Observatory practice) · rule: version-disclosure

Responses advertise server technology (Server: Fly/331937a822 (2026-10-23)), giving attackers a head start on matching known vulnerabilities to exact versions.

Business impact

Free reconnaissance: version banners let attackers filter exploit lists to what you actually run.

How to fix

Suppress or genericize Server and X-Powered-By headers at the server or CDN layer.

Evidence

• https://propel.earth/ — server: Fly/331937a822 (2026-10-23)

What this assessment does not claim

Automated checks cover a portion of the WCAG standard and a defined set of passive security observations. A clean automated result is not full WCAG conformance and not a guarantee of security; items marked “needs manual verification” require a human reviewer. No active exploitation, load testing, or access attempts were performed. Remediation, where purchased, is an explicit scope of work described in the service terms — it is not a promise that a site becomes “100% secure” or “fully accessible.”